COMPTIA SECURITY+ SY0-701 DOMAIN 4 · SECURITY OPERATIONS (28%)

Security+ 4.1 · Wireless Security Settings

Mestre CyberSec · **Lesson 4.1 — Wireless Security Settings** (10:54) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Config do AP: WPA3/SAE (moderno), WPA2/TKIP e WEP quebrados proibidos; RADIUS centralizado; WPS (Wi-Fi Protected Setup) inseguro — DISABLE.

💡 Key Exam Highlights & Critical Concepts

- WPA3/SAE = moderno; WEP/WPA nunca
- WPS (o botãozinho) é INSEGURO — desabilita sempre

🎯 Exam Tips & Typical CompTIA Scenarios

- 'deprecate WEP/WPA'=use WPA2/3

🧯 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 4.1 — Wireless Security Settings)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• WPA3 (Wi-Fi Protected Access 3)

The current modern wireless security standard that uses SAE (Simultaneous Authentication of Equals) for password-based authentication, providing protection against offline dictionary attacks and forward secrecy.

⚠ ***Exam Trap:*** *On the exam, WPA3 is always the BEST/correct answer when available; if WPA3 is mentioned as an option, choose it over WPA2.*

• SAE (Simultaneous Authentication of Equals)

A secure key exchange mechanism used in WPA3 that replaces the WPA2 4-way handshake, preventing offline dictionary/brute-force attacks by requiring an active handshake for every password guess attempt.

⚠ ***Exam Trap:*** *When the question describes a WPA3 attack mitigation for offline brute-force, the answer is SAE (not just WPA3 generically).*

• WPA2 (Wi-Fi Protected Access 2)

The previous-generation wireless security standard using PSK (Personal) or 802.1X (Enterprise) with AES-CCMP encryption; still acceptable but considered legacy compared to WPA3.

⚠ ***Exam Trap:*** *WPA2 with AES-CCMP is acceptable; WPA2 with TKIP is DEPRECATED — never choose TKIP as an encryption method on the exam.*

• TKIP (Temporal Key Integrity Protocol)

An older encryption protocol used with WPA/WPA2 that was deprecated due to vulnerabilities; replaced by the more secure AES-CCMP.

⚠ ***Exam Trap:*** *TKIP is a DEPRECATED/INSECURE option. If you see TKIP as an answer choice on the exam, it is a distractor — choose AES-CCMP or SAE instead.*

• WEP (Wired Equivalent Privacy)

The original wireless security protocol, now completely broken and crackable in seconds; must NEVER be used in any modern environment.

⚠ ***Exam Trap:*** *Any question mentioning WEP = 'deprecate/disable immediately.' It is the WORST answer for wireless security; migrating to WPA2/WPA3 is required.*

• RADIUS (Remote Authentication Dial-In User Service)

A centralized AAA (Authentication, Authorization, Accounting) server protocol used with 802.1X for Enterprise wireless authentication, providing scalable per-user credentials instead of a shared PSK.

⚠️ ***Exam Trap:*** *When the scenario says 'centralized wireless authentication for an enterprise,' the answer is WPA2/WPA3 Enterprise with RADIUS + 802.1X, NOT PSK.*

• 802.1X

A port-based Network Access Control (NAC) standard that authenticates devices/users connecting to a wired or wireless network via an authenticator (AP) and authentication server (RADIUS).

⚠️ ***Exam Trap:*** *Distinguish Personal mode (PSK/shared key) vs Enterprise mode (802.1X + RADIUS + per-user). Enterprise is always preferred for corporate environments.*

• WPS (Wi-Fi Protected Setup)

A convenience feature that simplifies connecting devices to a Wi-Fi network via PIN or push-button; considered highly insecure and vulnerable to brute-force attacks on the 8-digit PIN.

⚠️ ***Exam Trap:*** *ALWAYS DISABLE WPS on every AP — Professor Messer's #1 wireless hardening tip. The push-button/PIN feature is a guaranteed exam trap.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 WPA3 & Simultaneous Authentication of Equals (SAE)

🏠 **Real-World Analogy:** Under legacy WPA2, an attacker parked outside records the cryptographic 4-way handshake, takes it home, and runs GPU-accelerated offline dictionary attacks guessing 100 million passwords per second completely undetected. WPA3 with SAE (Simultaneous Authentication of Equals) mandates an active, live zero-knowledge cryptographic exchange for every single guess, rendering offline dictionary and brute-force attacks completely impossible.

🔍 **Root Cause & Background:** The legacy WPA2 4-way handshake derives session keys directly from the static PSK without forward secrecy. SAE implements the Dragonfly key exchange, enforcing live mutual authentication that neutralizes passive capture.

🛡️ **GRC Auditor Perspective:** Enforcing mandatory migration roadmaps to WPA3; verifying transition modes are disabled in high-security zones to prevent downgrade attacks; and auditing 192-bit cryptographic suite compliance.

⚠️ **How CompTIA Tests This:** Exam trigger: "technology that prevents offline dictionary and brute-force attacks against captured wireless handshakes" = SAE (Simultaneous Authentication of Equals) / WPA3.

📌 WPA2/WPA3-Enterprise (802.1X + RADIUS) vs. Pre-Shared Key (PSK)

🏠 **Real-World Analogy:** Personal mode (PSK) is handing the identical physical brass key to 500 employees: when one departs, you must replace every lock and re-cut 500 keys. Enterprise mode (802.1X + RADIUS) is an electronic turnstile reading individual smart badges: each worker authenticates with their unique corporate identity. When an employee is offboarded, the central directory revokes that single credential instantly without impacting anyone else.

🔍 **Root Cause & Background:** Shared PSKs eliminate individual non-repudiation and make credential rotation during employee offboarding operationally unsustainable. IEEE 802.1X ties access points directly to enterprise AAA servers (RADIUS), enabling individual user directory logins and certificate-based EAP-TLS.

🛡️ **GRC Auditor Perspective:** Auditing compliance against PCI-DSS and ISO 27001 standards strictly forbidding shared passphrases in production; inspecting RADIUS authentication shared secrets and certificate revocation lists (CRLs).

⚠️ **How CompTIA Tests This:** Exam trigger: "centralized wireless authentication where each user connects using their own unique credentials and access can be revoked individually" = WPA2/WPA3-Enterprise (802.1X / RADIUS).

📌 Mandatory Disabling of Insecure WPS & Deprecated Protocols (WEP/TKIP)

🏠 **Real-World Analogy:** Installing a 20-ton vault door but leaving an unmonitored plastic push-button on the sidewalk protected by a crude 4-digit code that pops open after two hours of automated guessing. WPS is a flawed home-convenience feature that must never touch an enterprise. Similarly, running WEP or WPA-TKIP is using a toy padlock that an intruder shims open in 15 seconds.

🔍 **Root Cause & Background:** WPS validates its 8-digit PIN in two separate halves (4 digits and 3 digits + checksum), collapsing the search space from 100 million to a trivial 11,000 attempts (crackable in hours via tools like Reaver). WEP suffers from 24-bit IV reuse, while TKIP was officially deprecated due to mathematical collision vulnerabilities.

🛡️ **GRC Auditor Perspective:** Technical wireless vulnerability assessments ensuring WPS broadcast beacons are disabled fleet-wide; enforcing baseline policies banning WEP and TKIP ciphers across all corporate controllers.

> ⚠️ **How CompTIA Tests This:** Exam trigger: "insecure quick-connect wireless feature using an 8-digit PIN vulnerable to brute-force that should ALWAYS be disabled" = WPS. "Deprecated wireless cipher that should NEVER be used" = WEP or TKIP.

📌 RF Signal Containment: Power Adjustment & Antenna Topologies

🏠 **Real-World Analogy:** Speaking in a low conversational tone inside a glass conference room rather than shouting through a megaphone that bleeds into the public street. Dialing back AP transmit power confines radio waves inside the building boundary. To bridge two separate buildings, instead of an omnidirectional ceiling bulb illuminating all directions, you use a laser-focused directional antenna (Yagi / parabolic dish).

🔍 **Root Cause & Background:** Factory-default APs run at 100% transmit power, broadcasting RF footprints into public spaces and enabling wardriving. Deploying omnidirectional antennas for point-to-point building links scatters RF energy indiscriminately.

🛡️ **GRC Auditor Perspective:** Reviewing predictive and active RF site survey heatmaps to confirm radio containment at building perimeters; inspecting directional antenna alignments on inter-building bridges.

> ⚠️ **How CompTIA Tests This:** Exam trigger: "prevent wireless signal from bleeding outside the facility into adjacent public parking areas" = Reduce transmit power. "Point-to-point wireless bridge between two buildings" = Directional antenna.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Eliminating offline dictionary and brute-force attacks against captured wireless handshakes	**WPA3 with SAE (Simultaneous Authentication of Equals)**
Centralized enterprise wireless authentication using individual user credentials with instant revocation	**WPA2/WPA3-Enterprise (802.1X + RADIUS)**
Vulnerable 8-digit PIN quick-connect setup feature that must always be disabled in enterprises	**WPS (Wi-Fi Protected Setup)**
Deprecated legacy wireless protocols and ciphers that must be retired immediately across all APs	**WEP & WPA-TKIP (Deprecated)**
Preventing wireless RF signal leakage beyond corporate walls into public streets or parking lots	**Transmit Power Reduction**
Connecting two corporate facilities across a boulevard using a focused point-to-point wireless bridge	**Directional Antenna (Yagi / Parabolic)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A hospital is refreshing its wireless infrastructure. The security team wants to eliminate the risk of offline dictionary attacks against captured WPA2-Personal handshakes for the guest SSID. Which wireless security setting should be configured on the APs for the guest SSID?

A) WPA2-Personal with AES-CCMP

B) WPA2-Enterprise with PEAP-MSCHAPv2

C) WPA3-Personal with SAE

D) Open authentication with a captive portal

QUESTION 2 · EXAM SCENARIO

A logistics company's new wireless barcode scanners only support WPA2-Personal with TKIP. The security policy prohibits TKIP because it is cryptographically weak. What should the administrator do?

A) Replace or upgrade the scanners so they support AES-CCMP or WPA3, then disable TKIP.

B) Enable WPA2/WPA3 mixed mode with TKIP for the scanners to eliminate single points of operational failure

C) Configure a hidden SSID with MAC filtering for the scanners across all hybrid on-premises and cloud clusters

D) Set the AP to WEP for scanner compatibility and segment them on a VLAN without disrupting production workload availability

QUESTION 3 · EXAM SCENARIO

A retail store still uses WEP on an AP for old inventory handhelds. A recent assessment flags WEP as a critical finding. Which action best addresses the finding?

A) Increase WEP key length from 64-bit to 128-bit to eliminate single points of operational failure

B) Migrate handhelds to WPA2/WPA3 and disable WEP on the AP.

C) Rotate the WEP key every week without disrupting production workload availability

D) Hide the SSID and reduce transmit power to enforce least privilege and reduce attack surfaces

QUESTION 4 · EXAM SCENARIO

A university wants each student and staff member to authenticate to Wi-Fi with individual credentials. The security team also needs centralized accounting and the ability to revoke one user's access without changing a shared key. Which AP configuration should be used?

A) WPA3-Personal with SAE across all hybrid on-premises and cloud clusters

B) WPA2-Personal with a long shared passphrase

C) WPS with push-button configuration to enforce least privilege and reduce attack surfaces

D) WPA2-Enterprise with 802.1X and RADIUS

QUESTION 5 · EXAM SCENARIO

A small business enables WPS on its AP to let employees connect printers easily. An auditor warns that the PIN method can be brute-forced. Which recommendation is most appropriate?

A) Disable WPS and use WPA3 or WPA2 with strong credentials or 802.1X.

B) Change the WPS PIN every 30 days to enforce least privilege and reduce attack surfaces

C) Use WPS push-button only during business hours through automated configuration orchestration pipelines

D) Restrict WPS to printer MAC addresses while ensuring strict audit log retention compliance

QUESTION 6 · EXAM SCENARIO

A company is concerned that attackers who obtain the Wi-Fi passphrase can connect rogue laptops to the corporate SSID. The network team must ensure only domain-managed devices can join. Which configuration best meets this requirement?

A) WPA3-Personal with SAE and a complex passphrase.

B) Hidden SSID with reduced signal strength through automated configuration orchestration pipelines

C) WPA2-Enterprise with 802.1X, EAP-TLS, and RADIUS.

D) WPA2-Personal with MAC address filtering using standardized security content automation profiles

QUESTION 7 · EXAM SCENARIO

An organization wants to deploy WPA3 but must support a set of older WPA2-only tablets for six months. Which deployment approach is most appropriate during the transition?

A) WPA2 with TKIP because it is compatible with WPA3 clients through automated configuration orchestration pipelines

B) WPA3-only mode to force immediate replacement while ensuring strict audit log retention compliance

C) WEP with 802.1X because it supports both client types using standardized security content automation profiles

D) WPA3/WPA2 mixed mode while planning to retire WPA2-only devices.

QUESTION 8 · EXAM SCENARIO

A security analyst captures a WPA2-Personal four-way handshake and attempts to crack it offline. The IT director asks which upgrade directly mitigates this attack. Which technology should be recommended?

A) TKIP in WPA2-Personal

B) SAE in WPA3-Personal

C) RADIUS with PAP to prevent unauthorized configuration drift across nodes

D) WPS PIN across all managed enterprise endpoints

QUESTION 9 · EXAM SCENARIO

A network administrator is configuring a new AP to use 802.1X. The RADIUS server is already running. Which step must be performed on the AP?

A) Configure the AP as a RADIUS client and specify the RADIUS server address and shared secret.

B) Configure a single pre-shared key for all RADIUS users to prevent unauthorized configuration drift across nodes

C) Enable WPS so clients can receive the RADIUS certificate across all managed enterprise endpoints

D) Set the AP to WEP and map users to VLANs while maintaining continuous telemetry and monitoring

QUESTION 10 · EXAM SCENARIO

A company's wireless policy states that no deprecated encryption protocols may be used on corporate APs. During an audit, the administrator finds an AP broadcasting a WPA2 network with TKIP enabled. What is the best corrective action?

A) Enable WPS to simplify client reconnection after the change.

B) Move the AP to a guest VLAN and keep TKIP for compatibility.

C) Change the TKIP key length to 256 bits while maintaining continuous telemetry and monitoring

D) Disable TKIP and configure AES-CCMP with WPA2 or WPA3.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — WPA3-Personal with SAE

WPA3-Personal with SAE uses Simultaneous Authentication of Equals, which provides a secure handshake resistant to offline dictionary attacks. WPA2-Personal with AES-CCMP still uses a shared passphrase and remains vulnerable to offline capture attacks. WPA2-Enterprise can provide individual authentication, but the scenario specifically targets the guest SSID's personal-mode offline dictionary risk. Open authentication with a captive portal provides no wireless encryption.

Question 2: Option A — Replace or upgrade the scanners so they support AES-CCMP or WPA3, then disable TKIP.

TKIP is deprecated and prohibited, so it should not remain enabled just for legacy scanners. The correct long-term fix is to replace or upgrade the scanners to support AES-CCMP or WPA3 and then disable TKIP. Hidden SSID, MAC filtering, and WEP do not fix the weak encryption, and WEP is even less secure.

Question 3: Option B — Migrate handhelds to WPA2/WPA3 and disable WEP on the AP.

WEP is broken regardless of key length or rotation, so it must be disabled. Migrating the handhelds to WPA2 or WPA3 and disabling WEP addresses the root cause. Increasing key length, rotating keys, hiding the SSID, and reducing transmit power do not fix WEP's cryptographic weaknesses.

Question 4: Option D — WPA2-Enterprise with 802.1X and RADIUS

WPA2-Enterprise with 802.1X and RADIUS supports individual user authentication, centralized accounting, and per-user revocation. WPA3-Personal and WPA2-Personal use shared credentials, so revoking one user requires changing the shared key for everyone. WPS is insecure and is not an enterprise authentication method.

Question 5: Option A — Disable WPS and use WPA3 or WPA2 with strong credentials or 802.1X.

WPS PIN is vulnerable to brute-force attacks and should be disabled. The secure recommendation is to turn off WPS and rely on WPA3/WPA2 with strong credentials or 802.1X. Changing the PIN, scheduling push-button, or MAC filtering does not remove the WPS attack surface.

Question 6: Option C — WPA2-Enterprise with 802.1X, EAP-TLS, and RADIUS.

WPA2-Enterprise with 802.1X, EAP-TLS, and RADIUS can require device certificates and validate each device before network access. WPA3-Personal and WPA2-Personal rely on shared credentials, so anyone with the passphrase may connect. Hidden SSID and MAC filtering are weak controls that can be bypassed.

Question 7: Option D — WPA3/WPA2 mixed mode while planning to retire WPA2-only devices.

WPA3/WPA2 mixed mode allows WPA3-capable clients to use WPA3 while temporarily supporting WPA2-only devices. WPA2 with TKIP uses a deprecated protocol, WPA3-only would break the tablets immediately, and WEP with 802.1X is not a valid secure combination.

Question 8: Option B — SAE in WPA3-Personal

SAE in WPA3-Personal replaces the WPA2-Personal PSK handshake with a resistant authentication exchange, preventing offline dictionary attacks on captured handshakes. TKIP is deprecated, RADIUS with PAP is insecure for credentials, and WPS PIN is vulnerable to brute force.

Question 9: Option A — Configure the AP as a RADIUS client and specify the RADIUS server address and shared secret.

For 802.1X, the AP acts as an authenticator and must be configured as a RADIUS client with the RADIUS server address and a shared secret. A single pre-shared key is WPA2-Personal, WPS is insecure and unrelated, and WEP should not be used.

Question 10: Option D — Disable TKIP and configure AES-CCMP with WPA2 or WPA3.

TKIP is a deprecated encryption protocol and must be removed from corporate APs. The correct action is to disable TKIP and use AES-CCMP with WPA2 or WPA3. Enabling WPS adds risk, moving to a guest VLAN does not fix weak encryption, and changing TKIP key length does not make it acceptable.